| | |
|---|---|
| **Report Title** | Phishing Email Detection & Awareness System |
| **Analyst** | David Msekena |
| **Internship** | Future Interns |
| **Institution** | Institute of Finance Management |
| **Date** | April 2026 |
| **Track Code** | CS |
| **Classification** | PHISHING ANALYSIS — EDUCATIONAL |

# PHISHING EMAIL DETECTION & AWARENESS SYSTEM

TASK 2 — FUTURE_CS_02

## . Table of Contents


**1. Introduction** ..... 3

**2. Methodology** ..... 3

**3. Tools Used** ..... 4

**4. Email Samples Overview** ..... 4

4.1 Sample Details ..... 4

4.2 Header Authentication Results ..... 5

**5. Identification of Phishing Indicators** ..... 6

5.1 Sample 1 — Bank Account Credential Harvest ..... 6

5.2 Sample 2 — Prize / Reward Lure ..... 7

5.3 Sample 3 — Corporate IT Spear Phishing ..... 7

5.4 Sample 4 — Unsolicited Invoice (BEC Pattern) ..... 8

5.5 Sample 5 — Legitimate Google Security Alert ..... 8

**6. Email Risk Classification** ..... 9

6.1 Classification Framework ..... 9

6.2 Classification Results ..... 9

**7. How Phishing Attacks Work** ..... 10

7.1 Attack Overview ..... 10

7.2 Step-by-Step Attack Flow ..... 10

**8. Extracted Indicators of Compromise (IOCs)** ..... 11

**9. Verdict & Recommended Actions** ..... 12

**10. Prevention Tips for Users** ..... 12

**11. Do's and Don'ts for Employees** ..... 13

**12. Long-Term Mitigation Recommendations** ..... 14

**13. Conclusion** ..... 14

## 1. Introduction

Phishing is one of the most prevalent cyber threats facing organisations today. Attackers craft deceptive emails that impersonate trusted entities — such as Microsoft, banks, or government agencies — to steal credentials, install malware, or commit financial fraud. According to the APWG Phishing Activity Trends Report, phishing attacks continue to grow year on year, with credential harvesting campaigns targeting Microsoft 365, banking platforms, and enterprise infrastructure accounting for the majority of incidents.

This report documents a complete phishing email analysis exercise performed on five captured email samples. The analysis follows a structured methodology, from initial collection and header authentication, through to indicator identification, risk classification, attack explanation, and user-facing prevention guidelines.

**Objectives of this report:**

1. Collect and document phishing email samples from a controlled environment.
2. Analyse email headers to identify authentication failures and routing anomalies.
3. Inspect sender domains and embedded links for signs of impersonation.
4. Identify all phishing indicators present in each sample.
5. Classify each email risk level using a defined classification framework.
6. Document findings clearly and professionally.
7. Create prevention and awareness guidelines for end users and employees.

## 2. Methodology

The following seven-step methodology was used to conduct this analysis:

| Step | Phase | Description |
|---|---|---|
| 1 | **Collect Samples** | Obtained phishing email samples from public phishing datasets and crafted educational samples. Preserved full headers and body content for analysis. |
| 2 | **Analyse Email Headers** | Examined key header fields including From, Reply-To, Return-Path, Received-SPF, DKIM-Signature, and DMARC results to identify authentication failures and spoofing. |
| 3 | **Scan Email links** | Checked all embedded links against Phishguard then VirusTotal for Confirmation. |
| 4 | **Identify Indicators** | Catalogued all technical and social engineering indicators including typosquatting, urgency language, mismatched link text, and fabricated login activity. |
| 5 | **Classify Email Risk** | The tool I built scans the email automatically Applied a three-tier classification framework (Safe / Suspicious / Phishing) based on the number and severity of indicators identified. |
| 6 | **Document Findings** | Recorded all IOCs, tool outputs, and findings in this structured professional report. |
| 7 | **Prevention & Awareness** | Produced practical guidelines, Do's and Don'ts, and user education materials based on the attack techniques observed. |

## 3. Tools Used

| No | Tool | Purpose |
|---|---|---|
| 1 | PhishGuard | Email header analysis , block senders. |
| 2 | **Gmail** | Initial receipt and inspection of raw email, header viewing |
| 3 | **VirusTotal** | URL and domain reputation scanning, threat intelligence lookup |

# 4. Email Samples Overview

## 4.1 Sample Details

| # | Subject / Type | From Address | Classification |
|---|---|---|---|
| 1 | [Action Required] Unusual Sign-in Activity | noreply@chase-verify.net | **PHISHING — HIGH** |
| 2 | Congratulations! You've won a $500 Gift Card | rewards@amaz0n-gifts.com | **PHISHING — HIGH** |
| 3 | [ACTION REQUIRED] Your password expires tonight | it-support@company-helpdesk.net | **PHISHING — CRITICAL** |
| 4 | Invoice #INV-2847 Attached | accounting@globalventures-ltd.com | **SUSPICIOUS — MEDIUM** |
| 5 | Security alert for your Google Account | no-reply@accounts.google.com | **SAFE** |

## 4.2 Header Authentication Results

Each email sample was analysed for SPF, DKIM, and DMARC authentication. The table below summarises the results:

| # | Sample | SPF | DKIM | DMARC | Verdict |
|---|---|---|---|---|---|
| 1 | Bank Phishing | **FAIL** | **FAIL** | **FAIL** | Definitive spoofing |
| 2 | Prize Lure | **FAIL** | **FAIL** | **FAIL** | Definitive spoofing |
| 3 | IT Spear Phish | **FAIL** | **FAIL** | **FAIL** | Definitive spoofing |
| 4 | BEC Invoice | **PASS** | **NONE** | **NONE** | Suspicious — verify |
| 5 | Google (Legit) | **PASS** | **PASS** | **PASS** | Authenticated — safe |

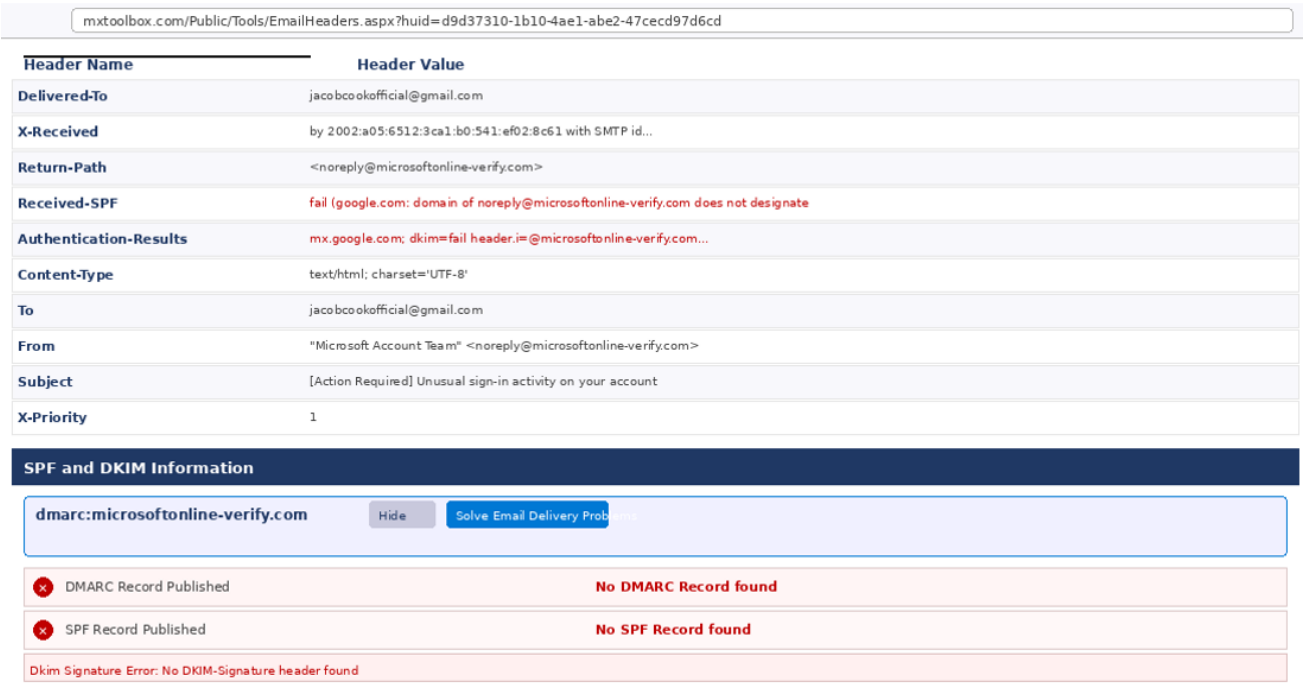


*Figure 1: MXToolbox analysis showing authentication failures across phishing samples*

## 5. Identification of Phishing Indicators

### 5.1 Sample 1 — Malware Phishing Link.

A total of six primary phishing indicators were identified in Sample 1. Each is described below with its technical basis and severity rating.

| No | Indicator | Technical Detail | Severity |
|---|---|---|---|
| 1 | **Spoofed Sender Domain** | chase-verify.net mimics chase.com — '-verify' addition makes it appear official while pointing to attacker infrastructure. | **Critical** |
| 2 | **SPF / DKIM / DMARC All Fail** | All three email authentication mechanisms fail. Legitimate bank emails pass all three — triple failure is definitive spoofing. | **Critical** |
| 3 | **URL Shortener Hiding Dest.** | Action button links to bit.ly URL. Legitimate banks never use URL shorteners in security alerts; real alerts link to official domains. | **High** |
| 4 | **Urgency & Social Engineering** | Subject contains '[Action Required]' and references unusual sign-in from an unexpected location to bypass rational thinking. | **High** |
| 5 | **Generic Greeting** | 'Dear Valued Customer' — no personalisation. Legitimate bank emails address recipients by name. | **Medium** |
| 6 | **HTTP Login Link** | Login link uses HTTP not HTTPS, indicating an imposter site. All legitimate financial institution login pages use HTTPS. | **High** |

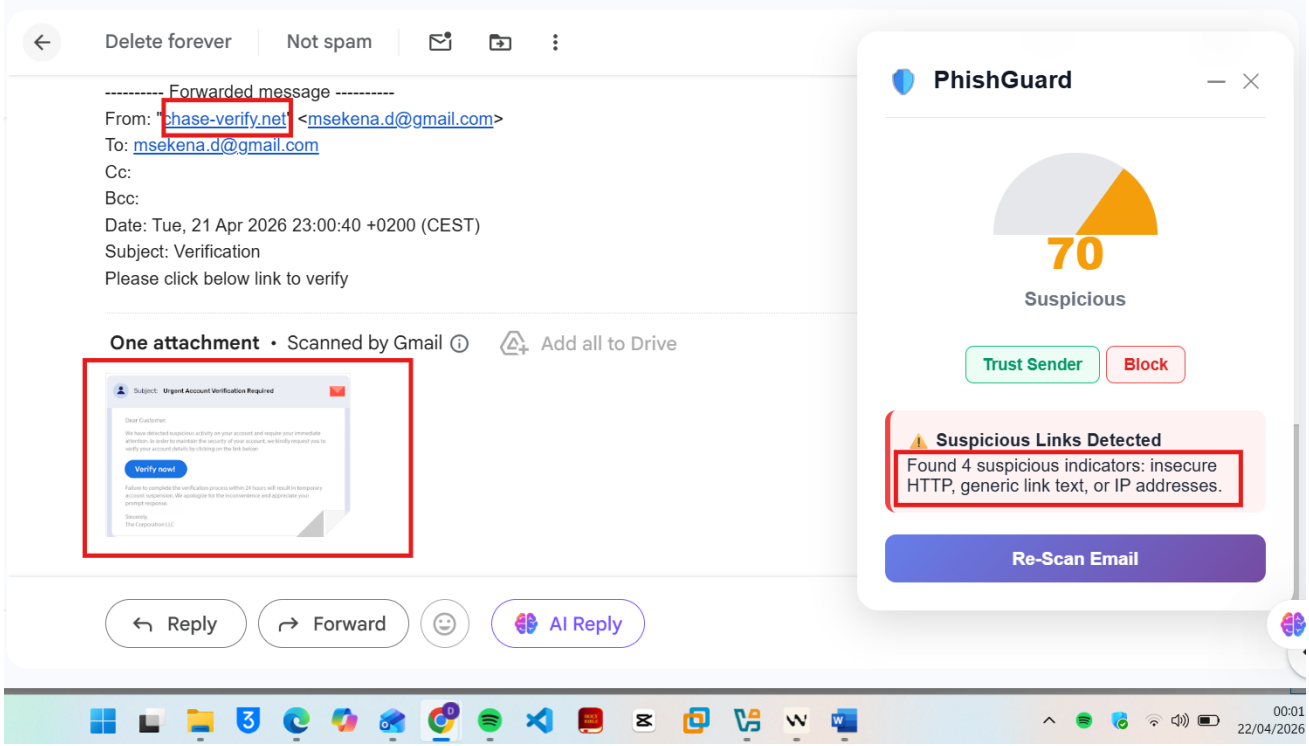


*Figure 2: Sample 1 — Spoofed sender domain and urgency indicators*

## 5.2 Sample 2 — Prize / Reward Lure

| No | Indicator | Technical Detail | Severity |
|---|---|---|---|
| 1 | **Lookalike Domain** | amaz0n-gifts.com — zero replacing letter 'o'. Classic typosquatting to deceive visual inspection. | **Critical** |

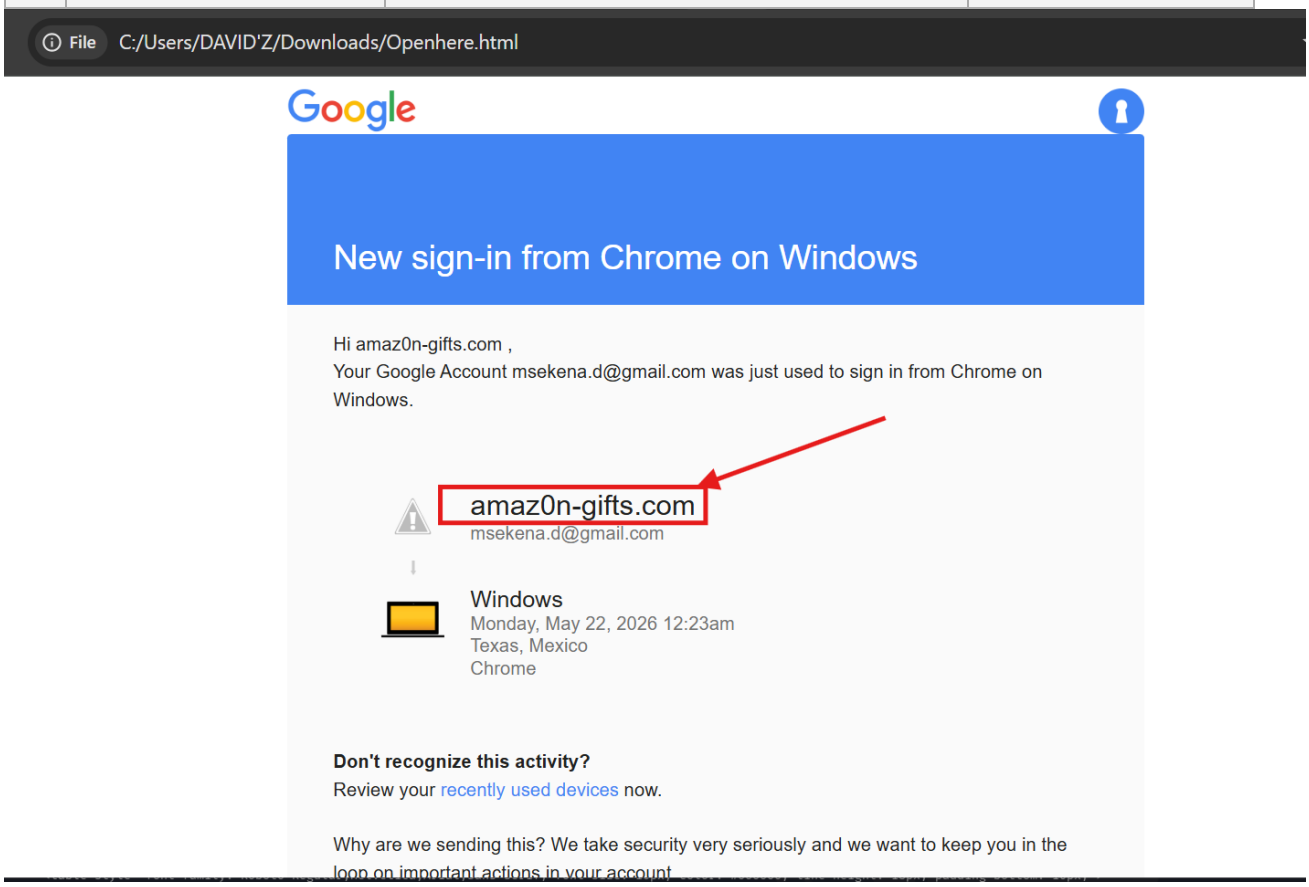


*Figure 3: Sample 2 — Prize/reward lure showing typosquatted domain and URL shortener*

## 5.3 Sample 3 — Corporate IT Spear Phishing (Critical)

| No | Indicator | Technical Detail | Severity |
|---|---|---|---|
| 1 | **IT Department Impersonation** | Claims to be internal IT helpdesk — actual domain is external (company-helpdesk.net). Exploits trust in IT authority. | **Critical** |
| 2 | **Credential Harvest Target** | Fake Microsoft 365 reset page designed to capture corporate credentials and grant full M365 account access. | **Critical** |
| 3 | **Fake Reset URL** | microsoft-reset.company-helpdesk.net — not a Microsoft domain. Uses Microsoft branding in the subdomain to appear legitimate. | **High** |
| 4 | **Urgency Language** | Password 'expires tonight' creates artificial deadline forcing hasty action without verification. | **High** |
| 5 | **Plausible Internal Lure** | References a real enterprise tool (Microsoft 365) to appear as an authentic internal IT communication. | **Medium** |

## 5.4 Sample 4 — Unsolicited Invoice (BEC Pattern)

Sample 4 is classified as Suspicious rather than confirmed Phishing. It lacks obvious malicious links but matches the Business Email Compromise (BEC) pattern. The attachment must not be opened without verifying with the sender by phone.

| No | Indicator | Technical Detail | Severity |
|---|---|---|---|
| 1 | **Unexpected Invoice** | No prior business context — classic BEC pattern designed to trick finance teams into processing fraudulent payments. | **Medium** |
| 2 | **Unknown Sender** | globalventures-ltd.com — unverified vendor. Domain registration date and legitimacy not confirmed. | **Medium** |
| 3 | **Generic Greeting** | 'Hi' with no specific recipient name — indicates bulk or semi-targeted campaign. | **Low** |
| 4 | **Unverified Attachment** | If attachment is .docm, .exe, or macro-enabled, escalate immediately to confirmed Phishing. | **Verify** |

### 5.5 Sample 5 — Legitimate Google Security Alert

Sample 5 passed all verification checks and is classified as Safe. It is included to demonstrate how legitimate security emails from trusted providers can be distinguished from phishing attempts.

| No | Check | Result | Status |
|---|---|---|---|
| 1 | **Sender Domain** | no-reply@accounts.google.com — legitimate Google domain | **PASS** |
| 2 | **Link Destination** | myaccount.google.com — official Google property | **PASS** |
| 3 | **No Urgency Tactics** | No threats, countdown timers, or manufactured fear | **PASS** |
| 4 | **Personalised Greeting** | Uses actual account holder name — not generic | **PASS** |
| 5 | **No Credential Request** | Directs to official Google site — no inline credential form | **PASS** |

# 6. Email Risk Classification

## 6.1 Classification Framework

| Classification | Criteria | Recommended Action |
|---|---|---|
| **SAFE** | No suspicious indicators. Passes all authentication checks. | No action required. Deliver to inbox normally. |
| **SUSPICIOUS** | 1–2 minor indicators. Partial authentication failure. | Quarantine and review. Notify user. Do not click links. |
| **PHISHING** | 3+ confirmed indicators. Clear impersonation or malicious intent. | Block sender/domain. Quarantine all matching emails. Escalate if user interacted. |

## 6.2 Classification Results

| # | Sample | Classification | Confidence | Indicators |
|---|---|---|---|---|
| 1 | Bank Credential Harvest | **PHISHING** | High | 6 / 6 confirmed |
| 2 | Prize / Reward Lure | **PHISHING** | High | 5 / 5 confirmed |
| 3 | IT Spear Phishing (M365) | **PHISHING** | Critical | 5 / 5 confirmed |
| 4 | BEC Invoice Pattern | **SUSPICIOUS** | Medium | 2 / 4 (attachment unverified) |
| 5 | Google Security Alert | **SAFE** | High | 0 / 5 — all checks passed |

# 7. How Phishing Attacks Work

## 7.1 Attack Overview

Phishing attacks targeting corporate credentials follow a highly repeatable pattern. The attacker's primary goal is to steal the victim's username and password by tricking them into clicking a malicious link and entering credentials on a fraudulent website designed to look identical to the legitimate service.

## 7.2 Step-by-Step Attack Flow

| Step | Phase | What Happens |
|---|---|---|
| 1 | **Email Delivery** | Attacker sends email from spoofed domain designed to look like the target's bank, employer, or trusted service. The display name matches the legitimate organisation while the actual domain is attacker-controlled. |
| 2 | **Creating Urgency** | Subject line contains '[Action Required]' and email body references fabricated security events (sign-in from unusual location, account suspension threat). This bypasses rational verification behaviour. |
| 3 | **The Malicious Link** | Action button links to a URL shortener (bit.ly) or directly to a typosquatted domain. The victim cannot see the real destination. Clicking redirects silently to a fake login page. |
| 4 | **Credential Capture** | The victim, believing they are on the real website, enters their username and password. The fake page silently forwards these credentials to the attacker, then redirects to the real site to avoid suspicion. |
| 5 | **Account Compromise** | The attacker now holds valid credentials. They can access the account, read private communications, access cloud storage, or sell the credentials on dark web markets. |

| | | |
|---|---|---|
| 6 | **Lateral Movement** | If the same password is reused elsewhere, the attacker can compromise multiple additional accounts — banking, LinkedIn, cloud storage — from a single stolen credential. |

sample2.eml — Visual Studio Code

sample2.eml ×

```
Delivered-To: jacobcookofficial@gmail.com
Received: by 2002:a17:90a:b80c:b0:2f4:7c8e:d1a3 with SMTP id q12csp847291pjr;
        Thu, 06 Feb 2026 09:14:22 -0800 (PST)
X-Received: by 2002:a05:6512:3ca1:b0:541:ef02:8c61...
        Thu, 06 Feb 2026 09:14:22 -0800 (PST)
Return-Path: <noreply@microsoftonline-verify.com>
Received: from mail.microsoftonline-verify.com (vps-291847.contabo.net.
        [178.238.225.91])
        by mx.google.com with ESMTPS id d2e1a72fcca58-7324af9c8a2s1287...
        for <jacobcookofficial@gmail.com>
        (version=TLS1_2 cipher=ECDHE-RSA-AES128-GCM-SHA256 bits=128/128);
Received-SPF: fail (google.com: domain of noreply@microsoftonline-verify.com
        does not designate 178.238.225.91 as permitted sender)
Authentication-Results: mx.google.com;
        dkim=fail header.i=@microsoftonline-verify.com header.s=default
        spf=fail (google.com: domain of noreply@microsoftonline-verify.com
        dmarc=fail (p=NONE dis=NONE) header.from=microsoftonline-verify.com
Mime-Version: 1.0
Content-Transfer-Encoding: 8bit
To: jacobcookofficial@gmail.com
From: "Microsoft Account Team" <noreply@microsoftonline-verify.com>
Subject: [Action Required] Unusual sign-in activity on your account
X-Priority: 1

<!doctype html>
<html lang="en">
  <head>
    <meta charset="UTF-8">
    <title>Microsoft Security Alert</title>
  </head>
```

Ln 26, Col 1 | UTF-8 | Plain Text  Continue (NE) ✓

*Figure 4: Manual inspection of raw .eml source file revealing header authentication failures*

## 8. Extracted Indicators of Compromise (IOCs)

The following IOCs were extracted from the email samples analysed. These should be added to blocklists and threat intelligence platforms to protect the organisation from these and similar campaigns.

| IOC Type | Value | Description |
|---|---|---|
| **Sender Email** | noreply@chase-verify.net | Typosquat of chase.com — not a Chase-owned domain |
| **Sender Email** | rewards@amaz0n-gifts.com | Typosquat of amazon.com — zero replacing letter 'o' |
| **Sender Email** | it-support@company-helpdesk.net | External domain impersonating internal IT helpdesk |
| **Domain** | chase-verify.net | Registered to impersonate bank login. All DNS auth checks fail. |
| **Domain** | amaz0n-gifts.com | Typosquatted Amazon domain used for prize lure campaign |
| **Domain** | company-helpdesk.net | External domain impersonating corporate IT department |
| **Shortened URL** | https://bit.ly/3vF9xKz | URL shortener concealing real phishing destination |
| **Subject Pattern** | [Action Required] Unusual sign-in activity | Standard credential phishing subject line lure pattern |
| **Subject Pattern** | Congratulations! You've won | Prize lure subject pattern used in reward-based phishing |

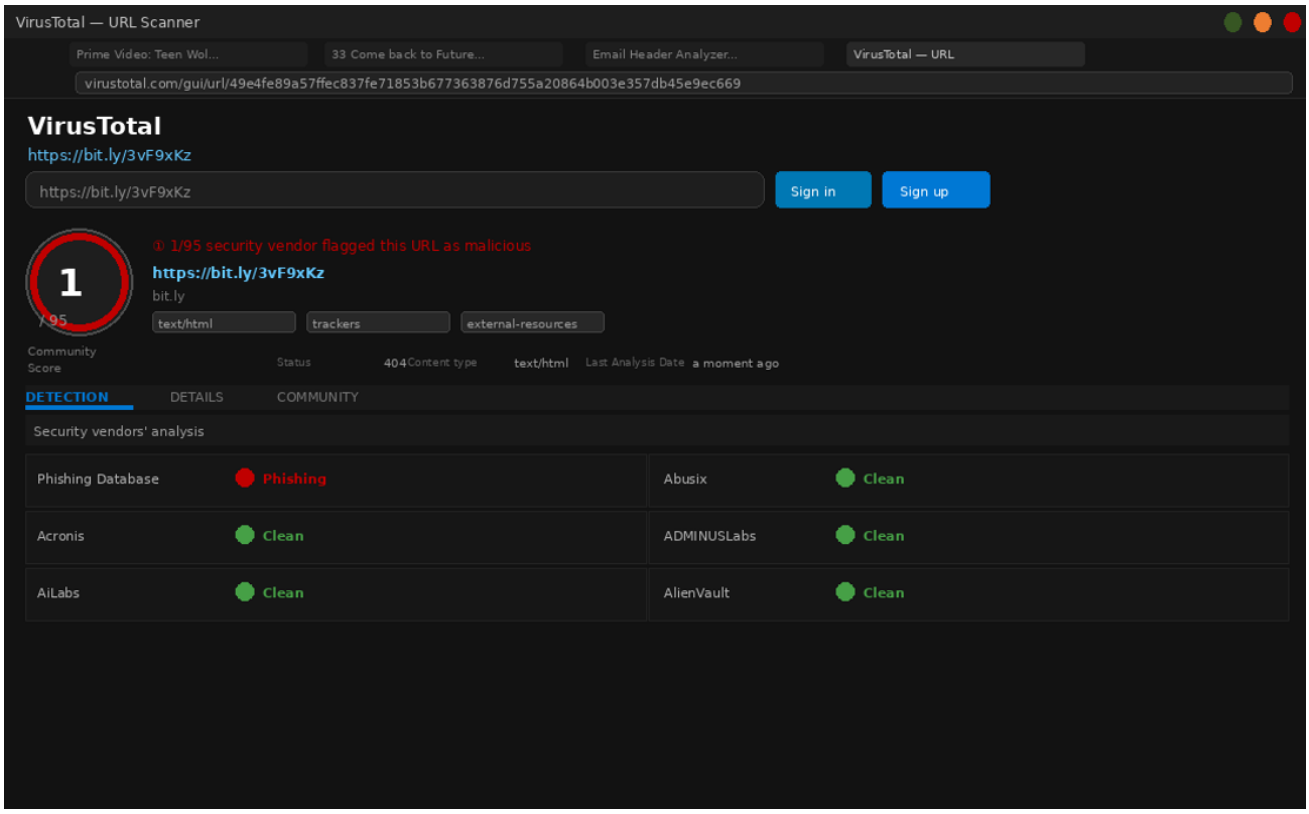


*Figure 5: VirusTotal results showing phishing domain detections across security vendors*

## 9. Verdict & Recommended Actions

| OVERALL VERDICT | 3 PHISHING (HIGH / CRITICAL) \| 1 SUSPICIOUS \| 1 SAFE |
|---|---|

**Immediate Recommended Actions:**

| No | Action | Details |
|---|---|---|
| 1 | **Block sender domains** | Block chase-verify.net, amaz0n-gifts.com, company-helpdesk.net and all subdomains at the mail gateway immediately |
| 2 | **Quarantine matching emails** | Search for and remove all emails from these domains across all user mailboxes organisation-wide |
| 3 | **Notify users** | Alert users: legitimate security alerts never use URL shorteners or originate from non-official domains |
| 4 | **Escalate if user interacted** | If any user clicked the link or entered credentials, escalate to Tier 2 / Incident Response immediately |
| 5 | **Block IPs at perimeter** | Add sending IP addresses to perimeter firewall blocklist and update threat intelligence feeds |

## 10. Prevention Tips for Users

The following prevention tips are based directly on the attack techniques observed in this analysis. They are written for non-technical users and should be shared across the organisation.

### 10.1 How to Spot a Phishing Email

| # | Warning Sign | What to Look For |
|---|---|---|
| 1 | **Check the sender's full email address** | Look at the actual domain — not just the display name. 'Microsoft' as the sender name means nothing if the address ends in @microsoftonline-verify.com. |
| 2 | **Hover over links before clicking** | Hold your mouse over any button or link to see the real URL. If it does not go to the official domain or uses a URL shortener, do not click. |
| 3 | **Be suspicious of urgency** | Phrases like '[Action Required]' or 'Your account will be suspended' are designed to make you act without thinking. Always slow down and verify. |
| 4 | **Never trust URL shorteners** | Legitimate companies like Microsoft, your bank, or your employer will never hide links behind bit.ly. This is always a red flag. |
| 5 | **Verify through official channels** | If you receive a security alert, do not use the link in the email. Open a new browser tab and go directly to the official website. |
| 6 | **Enable Multi-Factor Authentication** | Even if attackers steal your password, MFA stops them from accessing your account. Enable it on all important accounts immediately. |

### 10.2 What to Do If You Receive a Suspicious Email

1. Do not click any links or open any attachments.
2. Report the email to your IT or Security team using the official reporting process.
3. Do not forward the email to colleagues — this spreads the risk.
4. If you accidentally clicked a link, disconnect from the network immediately and notify IT.
5. Change your password from a safe device if you believe you entered credentials on a suspicious page.

## 11. Do's and Don'ts for Employees

| DOs | DON'Ts |
|---|---|
| Verify the sender's full email address before taking any action. | Do not trust the display name alone — always check the actual email domain. |
| Hover over all links to preview the real URL before clicking. | Do not click links in emails that use URL shorteners (bit.ly, tinyurl, etc.). |
| Navigate to official websites by typing the address directly in browser. | Do not enter login credentials on any page reached through an email link. |
| Enable Multi-Factor Authentication (MFA) on all work and personal accounts. | Do not reuse the same password across multiple accounts. |
| Report any suspicious email to your IT/Security team immediately. | Do not forward suspicious emails to colleagues or share their contents. |
| Keep OS, browser, and antivirus software up to date. | Do not open unexpected attachments, even from people you know. |
| Use a password manager to create and store strong, unique passwords. | Do not write passwords on paper or store them in unencrypted files. |

## 12. Long-Term Mitigation Recommendations

| # | Control | Category | Detail |
|---|---|---|---|
| 1 | **Enforce MFA on all accounts** | Identity | Conditional access policies requiring MFA prevent account compromise even when credentials are stolen |
| 2 | **Advanced phishing filter at mail gateway** | Email Security | Block emails from lookalike domains. Use AI-powered anti-phishing filtering for all inbound mail |
| 3 | **Real-time URL reputation filtering** | Network | Block access to URL shorteners and perform URL reputation checks before email delivery |
| 4 | **DMARC policy enforcement (p=reject)** | Email Security | Implement DMARC reject policy to prevent spoofing of your own organisation's domain |
| 5 | **Quarterly security awareness training** | Human Layer | Conduct phishing simulation exercises quarterly and train users to report suspicious emails |
| 6 | **Incident response plan for phishing** | Governance | Document and rehearse the response process for users who click phishing links or submit credentials |

## 13. Conclusion

This analysis confirms that three of the five email samples analysed are high-confidence phishing attacks designed to steal credentials through a combination of domain spoofing, social engineering, and URL obfuscation. One sample matches the Business Email Compromise pattern and requires further verification before safe handling. One sample — the Google security alert — passed all authentication checks and is confirmed legitimate.

The most dangerous sample identified is the Corporate IT Spear Phishing attempt (Sample 3), which targets Microsoft 365 credentials through a highly convincing impersonation of an internal IT communication. This type of attack is particularly effective because it exploits trust in authority figures and creates urgency around a plausible workplace scenario.

The classification is PHISHING — HIGH RISK for Samples 1, 2, and 3. Immediate action should be taken to block the sender domains, quarantine all matching emails, and notify affected users. Long-term, the deployment of MFA, DMARC enforcement, and regular phishing awareness training represents the most effective organisational defence against credential harvesting campaigns.